

**ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ
УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ,
МЕХАНИКИ И ОПТИКИ»**

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №1

Исследование баз данных угроз и уязвимостей. Калькулятор уязвимостей

Выполнил:

Студент гр. N3248

Жук Анастасия Валерьевна

Проверил:

Кондратенко Станислав Сергеевич

Санкт-Петербург

2024 г.

Цель работы: получить знания и навыки работы с различными базами данных угроз и уязвимостей.

Объекты:

1. Обязательный материал для ознакомления:

- 1.1. <https://habr.com/ru/company/pt/blog/266485/>
- 1.2. <https://habr.com/ru/company/ic-dv/blog/453756/>
- 1.3. <https://xakep.ru/2009/05/15/48221/#toc01>.
- 1.4. <https://habr.com/ru/company/xakep/blog/305262/>
- 1.5. <https://habr.com/ru/companies/tomhunter/articles/754812/>

2. БД угроз и уязвимостей:

- 2.1. ФСТЭК
- 2.2. Vulners
- 2.3. X-Force
- 2.4. Exploit Database
- 2.5. CERT/CC

3. Калькулятор CVSS. Метрики.

- 3.1. Атака высокой сложности будет проводится на физический уровень системы, при этом оказывается влияние на другие компоненты системы. Однако атака приводит только к нарушению целостности высокого уровня и доступности низкого. Взаимодействие с пользователем не требуется, а уровень привилегий - низкий. (1.б)
- 3.2. Предполагается, что есть сценарий для средств эксплуатации, средства устранения недоступны и подтверждена степень доверия к источнику информации об уязвимости. (2.г)
- 3.3. К уровню обеспечения КЦД заданы низкие требования, однако влияние на них оказывается высоким. При этом проводится атака низкой сложности на локальный уровень системы. Уровень привилегий в данном случае - высокий, взаимодействия с пользователем не происходит. Оказывается ли влияние на другие компоненты системы - неизвестно. (3.а)

Ход работы

База данных угроз и уязвимостей

Прежде чем перейти к описанию конкретных баз данных угроз и уязвимостей, стоит разобраться с некоторыми понятиями. База (банк) данных угроз/уязвимостей — это сведения об основных угрозах/уязвимостях, которые характерны для автоматизированных систем управления (АСУ), государственных информационных систем (ГИС) и информационных систем персональных данных (ИСПДн) [1]. Угроза — потенциальное или вероятностное событие, нарушающее ИБ. Уязвимость — слабое место в системе.

ФСТЭК (Федеральная Служба по Техническому и Экспортному Контролю)

Отвечает за обеспечение безопасности информации и применение технических средств защиты информации в России.

Банк данных угроз не структурирован (в нём нет иерархической структуры, угрозы располагаются в хронологическом порядке их обнаружения и публикации), но угрозы классифицированы по нарушителям, которые могут ими воспользоваться, и последствиям, которые использование этих угроз может повлечь (нарушение конфиденциальности, целостности или доступности информации) [1].

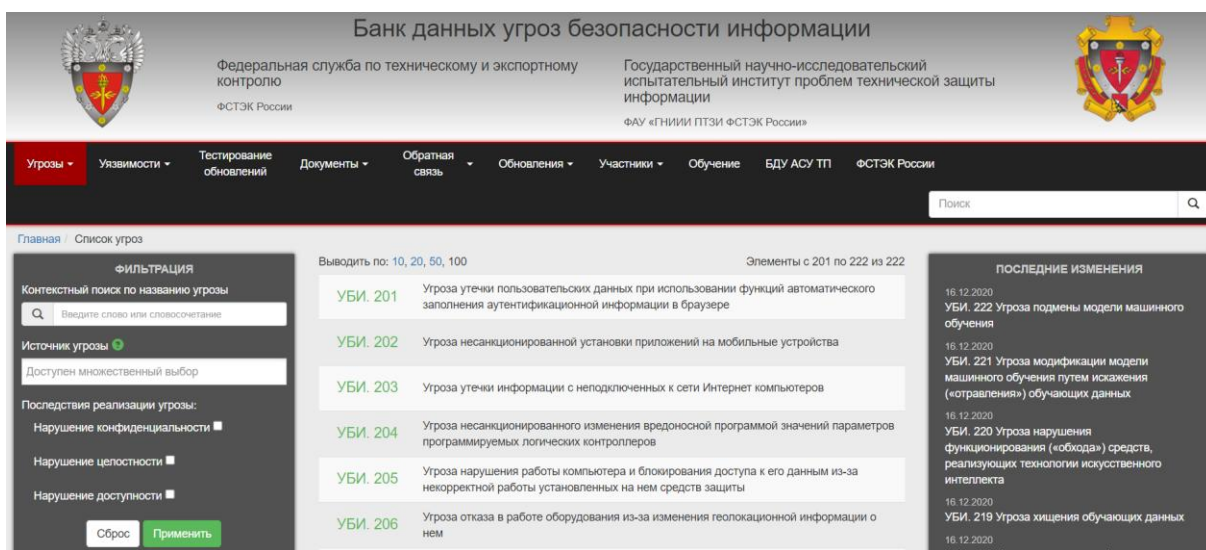


Рисунок 1 – База данных угроз ФСТЭК

Главная / Список угроз / УБИ.201

УБИ.201: Угроза утечки пользовательских данных при использовании функций автоматического заполнения аутентификационной информации в браузере

Вид ▾

Описание угрозы	Угроза заключается в возможности утечки пользовательских данных за счет использования реализованной в браузерах функции автоматического заполнения форм авторизации. Реализация данной угрозы обусловлена хранением в браузерах в открытом виде пользовательских данных, используемых для автозаполнения форм авторизации. Реализация данной угрозы возможна при условии, что пользователь использует браузер, в котором реализована и активирована функция автоматического заполнения форм авторизации
Источники угрозы	Внешний нарушитель со средним потенциалом
Объект воздействия	Аутентификационные данные пользователя (программное обеспечение)
Последствия реализации угрозы	Нарушение конфиденциальности

Рисунок 2 – Пример описание угрозы ФСТЭК

Помимо базы данных угроз есть еще и база данных уязвимостей. Уязвимости можно сортировать по идентификатору, по выявлению и по критичности.

Угрозы ▾ Уязвимости ▾ Тестирование обновлений Документы ▾ Обратная связь ▾ Обновления ▾ Участники ▾ Обучение БДУ АСУ ТП ФСТЭК России

Поиск

Главная / Список уязвимостей

ФИЛЬТРАЦИЯ

Контекстный поиск по названию уязвимости

Производитель ПО

Тип ПО

Программное обеспечение

Аппаратная платформа

Версия ПО

Выводить по: 10, 20, 50, 100

Сортировка ▾

Элементы с 1 по 10 из 60507

Последние изменения

16.09.2024

Уязвимость платформы MSHTML операционных систем Microsoft Windows, позволяющая нарушителю выполнить спуфинг-атаку

16.09.2024

Уязвимость конфигурации WOLFSSL_CHECK_SIG_FAULTS библиотеки SSL/TLS WolfSSL, позволяющая нарушителю получить несанкционированный доступ к защищаемой информации

16.09.2024

Уязвимость функции ntlm.download() пакета библиотек для символьной и статистической обработки естественного языка NLTK, позволяющая нарушителю выполнить произвольный код

16.09.2024

Уязвимость функции django.utils.html.urlize() программной платформы для веб-приложений Django, позволяющая нарушителю вызвать отказ в обслуживании

31.07.2024

Уязвимость функции django.utils.numberformat.floatformat() программной

Рисунок 3 – База данных уязвимостей ФСТЭК

Главная / Список уязвимостей / BDU-2024-07077

BDU-2024-07077: Уязвимость платформы MSHTML операционных систем Microsoft Windows, позволяющая нарушителю выполнить спуфинг-атаку

Вид ▾

Описание уязвимости	Уязвимость платформы MSHTML операционных систем Microsoft Windows связана с ошибками представления информации пользовательским интерфейсом. Эксплуатация уязвимости может позволить нарушителю, действующему удаленно, выполнить спуфинг-атаку
Вендор	Microsoft Corp.
Наименование ПО	Windows
Версия ПО	Server 2008 R2 SP1 (Windows) Server 2008 SP2 (Windows) Server 2012 R2 (Windows) Server 2012 (Windows) 10 (Windows)
Тип ПО	Операционная система
Операционные системы и аппаратные платформы	Microsoft Corp. Windows Server 2008 R2 SP1 64-bit Microsoft Corp. Windows Server 2008 SP2 32-bit Microsoft Corp. Windows Server 2012 R2 64-bit Microsoft Corp. Windows Server 2008 SP2 64-bit Microsoft Corp. Windows Server 2012
Тип ошибки	UI. Ложное представление критической информации пользовательским интерфейсом
Идентификатор типа ошибки	CVE-451
Класс уязвимости	Уязвимость кода
Дата выявления	10.09.2024
Базовый вектор уязвимости	CVSS 2.0: A/V/N/A/C/Lu/M/C/CH/CAC CVSS 3.0: A/V/N/A/CPR/N/UI/RS/UC/HI/H/HA/H
Уровень опасности уязвимости	Критический уровень опасности (Базовая оценка CVSS 2.0 составляет 10) Высокий уровень опасности (Базовая оценка CVSS 3.0 составляет 8.8)
Возможные меры по устранению уязвимости	Установка обновлений из доверенных источников. В связи со сложившейся обстановкой и введенными санкциями против Российской Федерации рекомендуется устанавливать обновления программного обеспечения только после оценки всех сопутствующих рисков. Компенсирующие меры: - использование антивирусного программного обеспечения для отслеживания средств эксплуатации уязвимости;
Статус уязвимости	Подтверждена производителем
Наличие эксплойта	Существует
Способ эксплуатации	Подмена при взаимодействии
Способ устранения	Обновление программного обеспечения
Информация об устранении	Уязвимость устранена
Ссылки на источники	https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-43461
Идентификаторы других систем	CVE: CVE-2024-43461
Прочая информация	Данные уточняются

Рисунок 4 – Пример описания уязвимости ФСТЭК

Данные постоянно обновляются и дополняются. На приложенных рисунках можно увидеть, что справа как у угроз, так и у уязвимостей, есть окошко с последними изменениями.

Vulners

Vulners — это очень большая и непрерывно обновляемая база данных ИБ-контента [2]. Сайт позволяет искать уязвимости, эксплойты, патчи, результаты bug bounty так же, как обычный поисковик ищет сайты. Vulners агрегирует и представляет в удобном виде шесть основных типов данных:

- Популярные базы уязвимостей;
- Вендорские бюллетени безопасности;
- Эксплойты из Exploit-DB и Metasploit;
- Nessus-плагины для детекта уязвимостей;
- Дисклозы багов с сайтов bug bounty программ;
- Публикации на тематических ресурсах.

Все это обрабатывается, каталогизируется, структурируется и доступно для поиска в любой момент. Угрозы можно сортировать по дате публикации или по оценке CVSS.

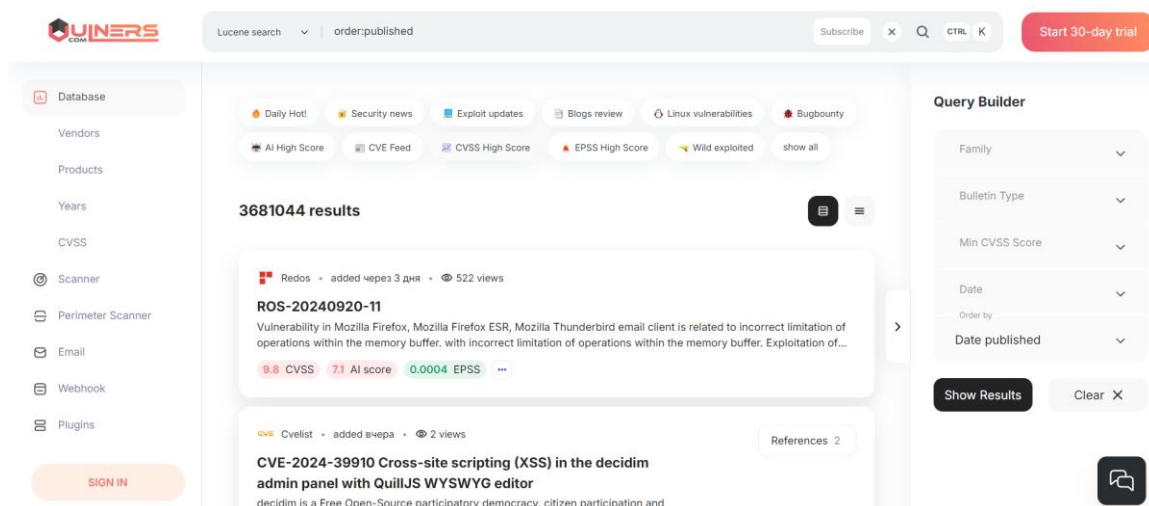


Рисунок 5 – База данных уязвимостей Vulners

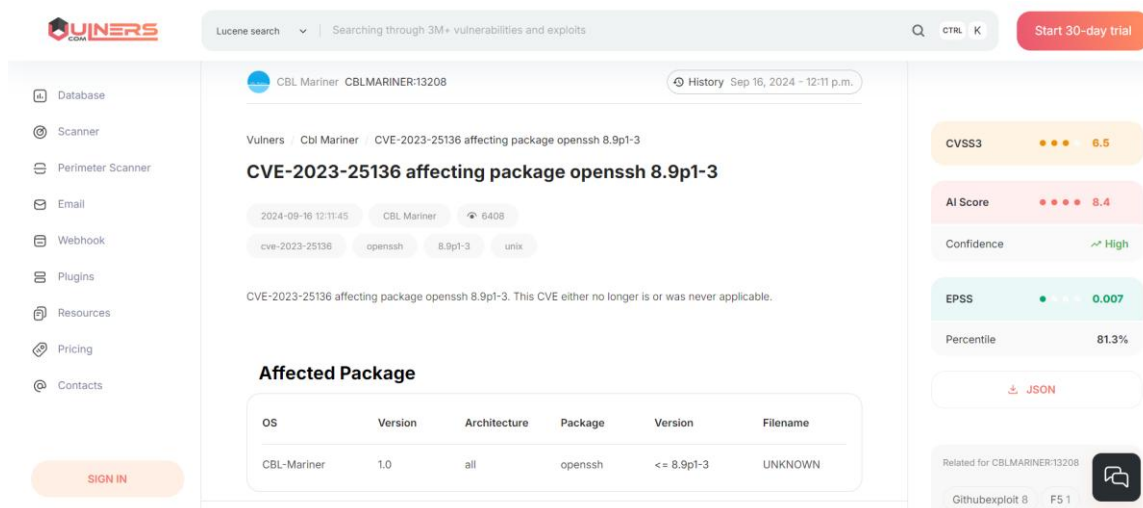


Рисунок 6 – Пример описания уязвимости Vulners

X-Force

База уязвимостей X-Force является проектом компании IBM [3]. В состав поля данных входят элементы, указывающие на преимущество базы X-Force: поле «Последствия», выражающее в формализованном виде возможный результат эксплуатации уязвимости; поле TemporalScore, являющееся элементом системы метрик CVSS, используемой для оценивания временных характеристик уязвимости. Также стоит отметить наличие в базе довольно подробных описаний и заключений об уязвимостях.

The screenshot shows the IBM X-Force Exchange interface. At the top, there is a search bar and navigation links. Below the search bar, the heading 'График операций' is displayed. A table lists several vulnerabilities, each with a 'VUL' status, a description, and a date.

Status	Description	Date
VUL	Новая уязвимость Apple Xcode information disclosure (CVE-2024-40862)	16 сент. 2024 г.
VUL	Новая уязвимость Apple Xcode security bypass (CVE-2024-44162)	16 сент. 2024 г.
VUL	Новая уязвимость Apple Xcode security bypass (CVE-2024-44191)	16 сент. 2024 г.
VUL	Новая уязвимость Apple Safari cross-site scripting (CVE-2024-40857)	16 сент. 2024 г.
VUL	Новая уязвимость Eaton Foreseer software cross-site scripting (CVE-2024-31414)	13 сент. 2024 г.
VUL	Новая уязвимость Eaton Foreseer software security bypass (CVE-2024-31415)	13 сент. 2024 г.
VUL	Новая уязвимость Eaton Foreseer software denial of service (CVE-2024-31416)	13 сент. 2024 г.
VUL	Новая уязвимость lunary-al lunary security bypass (CVE-2024-6087)	13 сент. 2024 г.

Рисунок 7 – База данных уязвимостей X-Force

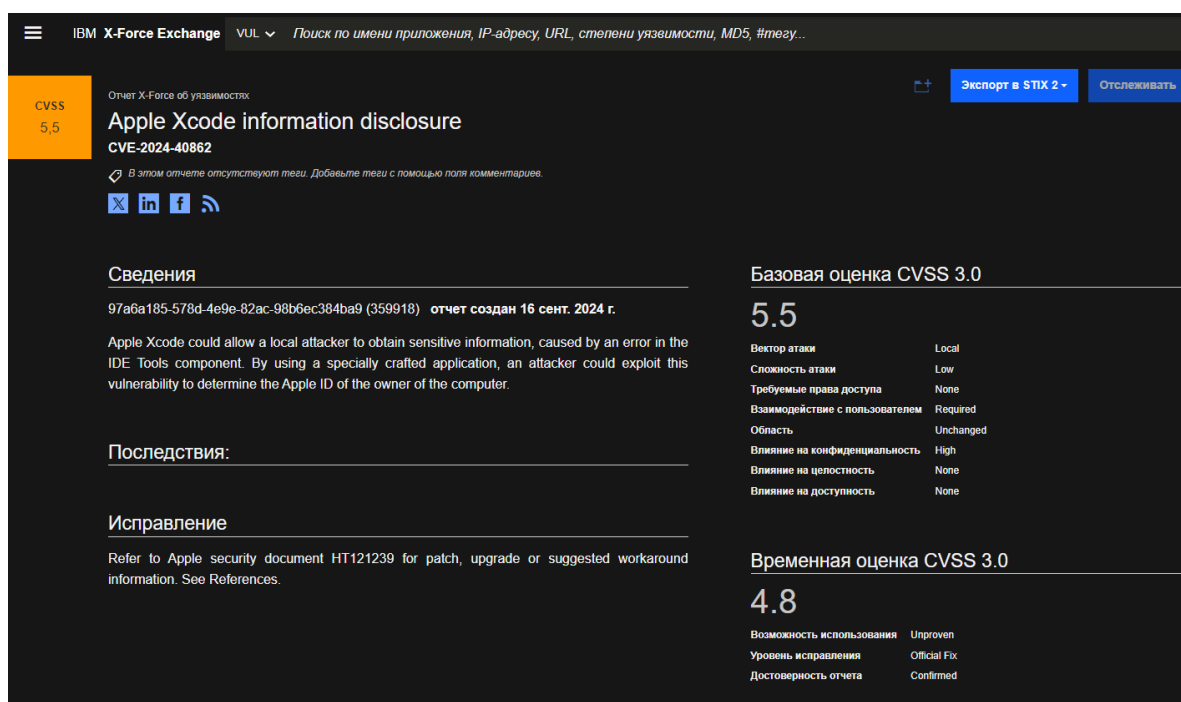


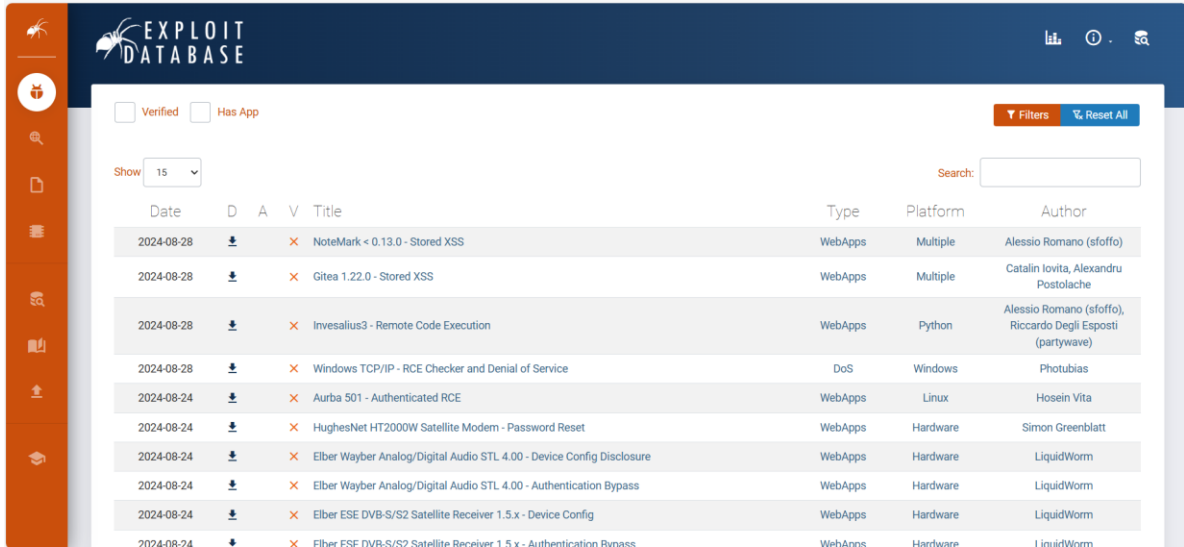
Рисунок 8 – Пример описания уязвимости X-Force

Exploit Database

Альтернативным подходом к каталогизации информации об обнаруженных уязвимостях ПО является регистрация не самих уязвимостей, а сценариев их эксплуатации (эксплойтов, exploits) или примеров эксплуатации уязвимости (Proof of Concept) [4]. Примером реализации такого подхода является база Exploit Database (<https://www.exploit-db.com>), сформированная организацией Offensive Security Team, специализирующейся на проведении тренингов в области информационной безопасности и тестирования компьютерных систем на проникновение.

Типичная запись в базе Exploit Database содержит краткое описание уязвимости, указание уязвимых версий приложений или их компонентов, уязвимую программную платформу (операционную систему или фреймворк веб-приложения), CVE-идентификатор, присвоенный данной уязвимости (при его наличии), и ссылки на сторонние источники информации об уязвимости. Однако самая важная и содержательная часть записи – это детальное описание самих причин возникновения уязвимости, места локализации уязвимости в коде (с непосредственной демонстрацией уязвимого фрагмента кода, если код

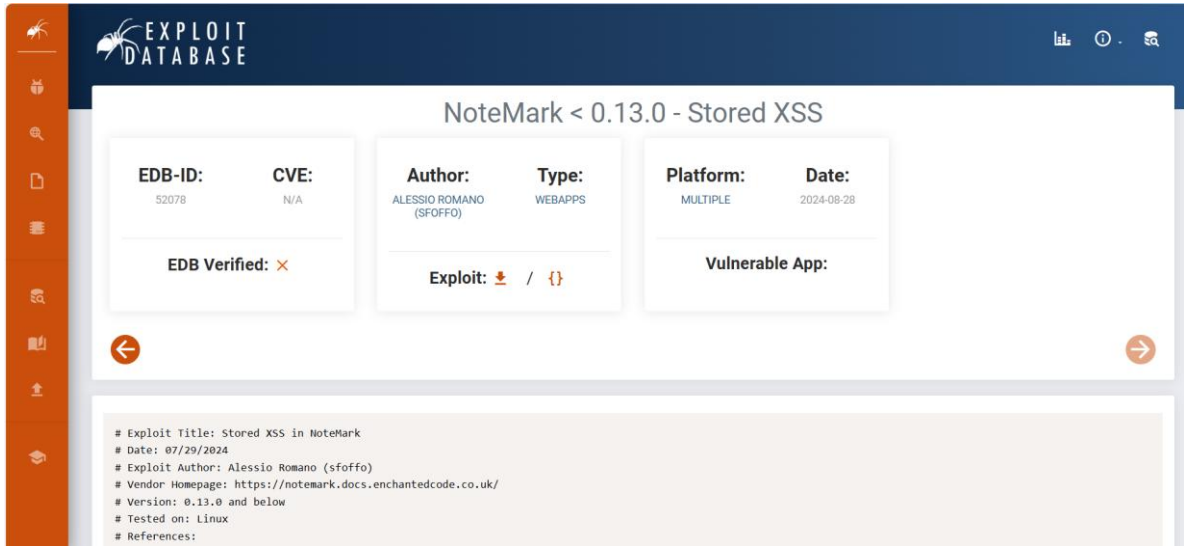
приложения публично доступен) и описание работоспособных сценариев эксплуатации уязвимостей или сценариев Proof of Concept (PoC).



The screenshot shows the Exploit Database interface. At the top, there's a search bar and filters for 'Verified' and 'Has App'. Below this is a table of vulnerabilities. The table has columns for Date, D (Download), A (Add), V (Verify), Title, Type, Platform, and Author. The first few entries are:

Date	D	A	V	Title	Type	Platform	Author
2024-08-28				NoteMark < 0.13.0 - Stored XSS	WebApps	Multiple	Alessio Romano (sfoffo)
2024-08-28				Gitea 1.22.0 - Stored XSS	WebApps	Multiple	Catalin Iovita, Alexandru Postolache
2024-08-28				Invesalius3 - Remote Code Execution	WebApps	Python	Alessio Romano (sfoffo), Riccardo Degli Esposti (partywave)
2024-08-28				Windows TCP/IP - RCE Checker and Denial of Service	DoS	Windows	Photobias
2024-08-24				Aurba 501 - Authenticated RCE	WebApps	Linux	Hosein Vita
2024-08-24				HughesNet HT2000W Satellite Modem - Password Reset	WebApps	Hardware	Simon Greenblatt
2024-08-24				Elber Wayber Analog/Digital Audio STL 4.00 - Device Config Disclosure	WebApps	Hardware	LiquidWorm
2024-08-24				Elber Wayber Analog/Digital Audio STL 4.00 - Authentication Bypass	WebApps	Hardware	LiquidWorm
2024-08-24				Elber ESE DVB-S/S2 Satellite Receiver 1.5.x - Device Config	WebApps	Hardware	LiquidWorm
2024-08-24				Fiber FSF DVR-S/S2 Satellite Receiver 1.5.x - Authentication Bypass	WebApps	Hardware	LiquidWorm

Рисунок 9 – База данных уязвимостей Exploit Database



The screenshot shows the detailed view of a vulnerability in the Exploit Database. The title is 'NoteMark < 0.13.0 - Stored XSS'. Below the title, there are several fields:

- EDB-ID:** 52078
- CVE:** N/A
- Author:** ALESSIO ROMANO (SFOFFO)
- Type:** WEBAPPS
- Platform:** MULTIPLE
- Date:** 2024-08-28
- EDB Verified:**
- Exploit:** /
- Vulnerable App:**

At the bottom, there is a section for the exploit details, including the title, date, author, vendor homepage, version, tested on, and references.

Рисунок 10 – Пример описания уязвимости Exploit Database

CERT/CC

База VND (Vulnerability Notes Database, <https://www.kb.cert.org/vuls/>), поддерживаемая центром реагирования CERT/CC при Институте программной инженерии в университете Карнеги-Меллона, США.

Каждая запись в базе VND агрегирует информацию о множестве сходных уязвимостей для какого-либо конкретного ПО, ссылаясь на множество соответствующих CVE идентификаторов [4]. Записи в базе VND содержат подробное и детальное руководство по устранению уязвимостей и \ или предотвращению их эксплуатации злоумышленником, а также обзор текущей

ситуации с наличием или успешным закрытием обнаруженной уязвимости различными вендорами (в случае, когда уязвимым оказывается библиотечный компонент, используемый несколькими производителями ПО).

Недостатками базы VND являются редкие обновления (единицы раз в месяц) и слабый охват всех существующих уязвимостей, что существенно ограничивают полезность данного каталога уязвимостей для оперативного реагирования на новые уязвимости ПО.

Carnegie Mellon University

Search vulnerability notes

Q

Software Engineering Institute

CERT Coordination Center

Home

Notes

Search

Report a Vulnerability

Disclosure Guidance

VINCE

Home > Notes

CERT/CC Vulnerability Notes Database

Published	Public	Updated	ID	CVSS	Title
2024-08-30	2024-07-25	2024-08-30	VU#455367		Insecure Platform Key (PK) used in UEFI system firmware signature
2024-07-30	2024-07-30	2024-08-06	VU#244112		Multiple SMTP services are susceptible to spoofing attacks due to insufficient enforcement
2024-07-09	2024-07-09	2024-07-10	VU#312260		Use-after-free vulnerability in lighttpd version 1.4.50 and earlier
2024-07-09	2024-07-09	2024-09-11	VU#456537		RADIUS protocol susceptible to forgery attacks.
2024-04-30	2024-04-30	2024-08-23	VU#163057		BMC software fails to validate IPMI session.
2024-04-29	2024-04-29	2024-05-03	VU#238194		R Programming Language implementations are vulnerable to arbitrary code execution during deserialization of rdc and rdy files

Рисунок 11 – База данных уязвимостей CERT/CC

Carnegie Mellon University

Search vulnerability notes

Q

Software Engineering Institute

CERT Coordination Center

Home

Notes

Search

Report a Vulnerability

Disclosure Guidance

VINCE

Home > Notes > VU#455367

Insecure Platform Key (PK) used in UEFI system firmware signature

Vulnerability Note VU#455367

Original Release Date: 2024-08-30 | Last Revised: 2024-08-30

Print

Twitter

Facebook

Overview

A vulnerability in the user of hard-coded Platform Keys (PK) within the UEFI framework, known as PKfail, has been discovered. This flaw allows attackers to bypass critical UEFI security mechanisms like Secure Boot, compromising the trust between the platform owner and firmware and enabling manipulation of sensitive system settings.

Description

ABOUT VULNERABILITY NOTES >

CONTACT US ABOUT THIS VULNERABILITY >

PROVIDE A VENDOR STATEMENT >

Рисунок 12 – Пример описания уязвимости CERT/CC

Калькулятор CVSS. Метрики

Расчет метрик. Задачи:

1.6) Атака высокой сложности будет проводится на физический уровень системы, при этом оказывается влияние на другие компоненты системы. Однако атака приводит только к нарушению целостности высокого уровня и доступности низкого. Взаимодействие с пользователем не требуется, а уровень привилегий - низкий.

Ответ: 5.6

Вектор CVSS v3: (AV:P/AC:H/PR:L/UI:N/S:C/C:N/I:H/A:L)

Решение:

Базовые метрики  5.6

AV:P/AC:H/PR:L/UI:N/S:C/C:N/I:H/A:L

Базовая оценка (BS): 5.6

Вектор атаки (AV):

Сетевой (N)	Смежная сеть (A)	Локальный (L)	Физический (P)
-------------	------------------	---------------	----------------

Сложность атаки (AC):

Высокая (H)	Низкая (L)
-------------	------------

Уровень привилегий (PR):

Высокий (H)	Низкий (L)	Не требуется (N)
-------------	------------	------------------

Взаимодействие с пользователем (UI):

Требуется (R)	Не требуется (N)
---------------	------------------

Влияние на другие компоненты системы (S):

Не оказывает (U)	Оказывает (C)
------------------	---------------

Влияние на конфиденциальность (C):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	-------------

Рисунок 13 – Решение 1-ой задачи (часть 1)

Влияние на целостность (I):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	-------------

Влияние на доступность (A):

Не оказывает (N)	Низкое (L)	Высокое (H)
------------------	------------	-------------

Рисунок 14 – Решение 1-ой задачи (часть 2)

2.г) Предполагается, что есть сценарий для средств эксплуатации, средства устранения недоступны и подтверждена степень доверия к источнику информации об уязвимости.

Ответ: 5.5

Вектор CVSS v3: (E:F/RL:U/RC:C)

Решение:

Временные метрики  5.5

E:F/RL:U/RC:C

Временная оценка (TS): 5.5

Доступность средств эксплуатации (E):

Не определено (X)	Высокая (H)	Есть сценарий (F)	Есть PoC-код (P)	Теоретическая (U)
-------------------	-------------	-------------------	------------------	-------------------

Доступность средств устранения (RL):

Не определено (X)	Недоступно (U)	Рекомендации (W)	Временное (T)	Официальное (O)
-------------------	----------------	------------------	---------------	-----------------

Степень доверия к информации об уязвимости (RC):

Не определено (X)	Подтверждена (C)	Достоверные отчеты (R)	Отчеты (U)
-------------------	------------------	------------------------	------------

Рисунок 15 – Решение 2-ой задачи

3.а) К уровню обеспечения КЦД заданы низкие требования, однако влияние на них оказывается высоким. При этом проводится атака низкой сложности на локальный уровень системы. Уровень привилегий в данном случае - высокий, взаимодействия с пользователем не происходит. Оказывается ли влияние на другие компоненты системы - неизвестно.

Ответ: 5.7

Вектор CVSS v3:

(CR:L/IR:L/AR:L/MAV:L/MAC:L/MPR:H/MUI:N/MC:H/MI:H/MA:H)

Решение:

Контекстные метрики

5.7

CR: L/IR: L/AR: L/MAV: L/MAC: L/MPR: H/MUI: N/MC: H/MI: H/MA: H

Контекстная оценка (ES): 5.7

Требования к конфиденциальности (CR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Требования к целостности (IR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Требования к доступности (AR):

Не определено (X)	Низкие (L)	Средние (M)	Высокие (H)
-------------------	------------	-------------	-------------

Вектор атаки (корр.) (MAV):

Не определено (X)	Сетевой (N)	Смежная сеть (A)	Локальный (L)	Физический (P)
-------------------	-------------	------------------	---------------	----------------

Сложность атаки (корр.) (MAC):

Не определено (X)	Высокая (H)	Низкая (L)
-------------------	-------------	------------

Рисунок 16 – Решение 3-ей задачи (часть 1)

Уровень привилегий (корр.) (MPR):

Не определено (X)	Высокий (H)	Низкий (L)	Не требуется (N)
-------------------	-------------	------------	------------------

Взаимодействие с пользователем (корр.) (MUI):

Не определено (X)	Требуется (R)	Не требуется (N)
-------------------	---------------	------------------

Влияние на другие компоненты системы (корр.) (MS):

Не определено (X)	Не оказывает (U)	Оказывает (C)
-------------------	------------------	---------------

Влияние на конфиденциальность (корр.) (MC):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Влияние на целостность (корр.) (MI):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Влияние на доступность (корр.) (MA):

Не определено (X)	Не оказывает (N)	Низкое (L)	Высокое (H)
-------------------	------------------	------------	-------------

Рисунок 17 – Решение 3-ей задачи (часть 2)

Отличия CVSS v.4 от предыдущих

Каждое усовершенствование калькулятора делается с целью увеличения точности оценки уязвимости. Путем увеличения количества деталей увеличивается сложность оценки уязвимости, а значит она становится более точной.

В четвертой версии путем введения новых параметров при оценке уязвимостей постарались учесть конкретные обстоятельства, которые необходимы для их эксплуатации.

Появилась номенклатура, позволяющая понять, сколько метрик учитывается при оценке уязвимости [5]. Соответственно, эти изменения повышают качество оценки уязвимости: чем больше метрик используется для оценки уязвимости, тем качественнее она будет.

Таблица 1 – Номенклатура

Название номенклатуры	Описание номенклатуры
CVSS-B	Базовые метрики
CVSS-BT	Базовые метрики + Метрики угроз
CVSS-BE	Базовые метрики + Контекстные метрики
CVSS-BTE	Базовые метрики + Метрики угроз + Контекстные метрики

Изменения метрик

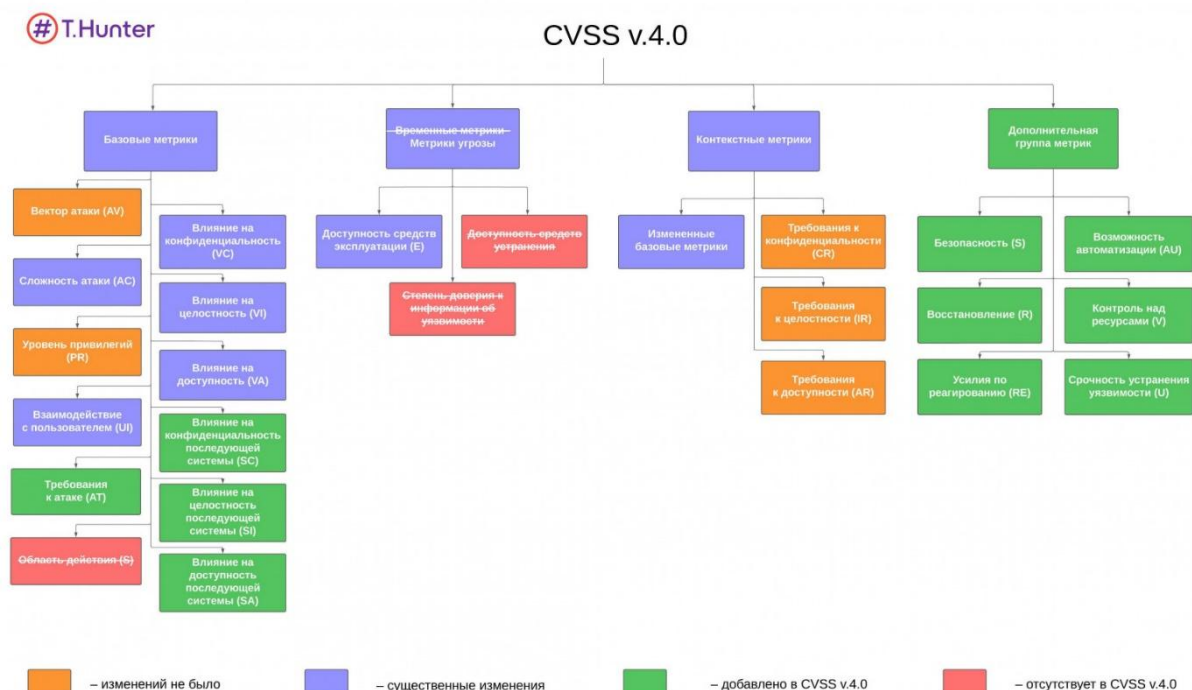


Рисунок 18 – Метрики в CVSS v.4.0

Изменения в базовой группе метрик

Одним из ключевых улучшений CVSS v.4 является внедрение более точной детализации в ее базовых метриках.

1. Новая базовая метрика **“Требования к атаке (AT)”**, которая разделяет предыдущую метрику **“Сложность атаки (AC)”** на две, позволяя более детально оценить условия, необходимые для атаки:
 - Сложность атаки (AC) – определение необходимости злоумышленнику предпринимать действия по уклонению или обходу защитных средств в процессе эксплуатации уязвимости.
 - Требования к атаке (AT) – показатель отражает наличие особых условий выполнения и развертывания, существующих в системе, и от которых зависит реализация успешной атаки.
2. Следующее обновление было внесено для показателя **“Взаимодействие с пользователем (UI)”** с целью обеспечения более детальной оценки уровня взаимодействия с пользователем.

Значение метрики оценивается по обновленным показателям:

- None (N) – для успешной эксплуатации уязвимости не требуется участие пользователя.
- Passive (P) – для успешной эксплуатации уязвимости необходимо незначительное взаимодействие пользователя с уязвимым компонентом и/или полезной нагрузкой злоумышленника. От пользователя требуется совершение произвольных действий.
- Active (A) – для успешного использования уязвимости необходимо, чтобы пользователь, выполняя конкретные действия, сознательно взаимодействовал с уязвимым компонентом и/или полезной нагрузкой злоумышленника.

3. С новой версией мы больше не увидим показатель **"Область применения (S)"**. Удаление метрики произошло из-за отсутствия ясности в ее использовании, что привело к несогласованной оценке уязвимостей.

По этой причине показатель "Область применения (S)" был отменен в пользу двух наборов показателей воздействия, которые отражают дополнительные аспекты риска, такие как:

- Влияние уязвимости на систему – конфиденциальность (VC), целостность (VI), доступность (VA).
- Влияние на последующую систему (системы) – конфиденциальность (SC), целостность (SI), доступность (SA).

Переименование и упрощение метрик угроз

С новой версией CVSS произошли изменения в названии группы временных метрик: "Временные метрики" → "Метрики угроз", а также:

- Удалены метрики "Уровень исправления (RL)" и "Достоверность отчета (RC)".
- Внесено изменение названия метрики: "Зрелость кода эксплойта (E)" → "Доступность средств эксплуатации (E)".
- Значения High (H) и Functional (F) для метрики "Доступность средств эксплуатации (E)" объединены в одно значение Attacked (A).

Добавление новой группы метрик

В CVSS v.4.0 внесена новая необязательная группа показателей, называемая “*Дополнительная группа метрик*”.

Группа включает в себя показатели, которые описывают и измеряют дополнительные внешние атрибуты уязвимости:

- **Безопасность (S)** – основное внимание сосредотачивается на потенциальном воздействии использования уязвимости на физическую безопасность людей.

Значение оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.
- *Present (P)* – катастрофические, критические или допустимые последствия уязвимости (категории последствий IEC 61508).
- *Negligible (N)* – незначительные последствия уязвимости (категория последствий IEC 61508).

Категории последствий IEC 61508: катастрофический – многочисленные человеческие жертвы, критический – потеря одной жизни, допустимый – серьезные травмы, незначительный – незначительные травмы.

- **Возможность автоматизации (AU)** – оценивается возможность злоумышленника автоматизировать использование уязвимости.

Значение оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.
- *No (N)* – злоумышленник не может автоматизировать использование уязвимости в жизненном цикле атаки, а именно в разведке, вооружении, доставке и эксплуатации.
- *Yes (Y)* – злоумышленник может автоматизировать использование уязвимости в жизненном цикле атаки, а именно в разведке, вооружении, доставке и эксплуатации.

- **Восстановление (R)** – данный показатель измеряет устойчивость системы и способность организации восстановиться после атаки.

Значение метрики оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.

- *Automatic (A)* – автоматическое восстановление работоспособности системы после атаки.
- *User (U)* – восстановление работоспособности системы после атаки требует ручное вмешательство.
- *Irrecoverable (I)* – после атаки система восстановлению не подлежит.
- **Контроль над ресурсами (V)** – этот показатель отражает уровень доступа к ресурсам уязвимой системы. Позволяет определить, имеет ли уязвимая система ограниченный доступ к ресурсам или, наоборот, имеет возможность доступа к нескольким ресурсам.

Значение метрики оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.
- *Diffuse (D)* – атакуемая система, которая содержит уязвимый компонент, имеет ограниченные ресурсы.
- *Concentrated (C)* – атакуемая система, которая содержит уязвимый компонент, имеет доступ к нескольким ресурсам.
- **Усилия по реагированию (RE)** – показатель измеряет уровень сложности необходимых действий для реагирования на уязвимость и успешного ее устранения. Этот показатель позволяет определить оценку устранения организацией данной уязвимости, что, в свою очередь, помогает определить приоритетность уязвимостей и способы их устранения.

Значение метрики оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.
- *Low (L)* – усилия по реагированию на уязвимость не требуют незамедлительных действий, для устранения уязвимости не потребуются значительные усилия.
- *Moderate (M)* – усилия по реагированию на уязвимость зависят от конечного пользователя - от совершенных с его стороны действий для устранения уязвимости.
- *High (H)* – усилия по реагированию и устранению уязвимости требуют значительных усилий.

- **Срочность устранения уязвимости (U)** – этот показатель позволяет провайдерам оценить, насколько срочно необходимо устранить уязвимость в конкретном продукте или услуге.

Значение метрики оценивается по следующим показателям:

- *Not Defined (X)* – показатель не был оценен.
- *Red* – воздействие уязвимости имеет наивысшую срочность, требуются незамедлительные меры для ее устранения.
- *Amber* – воздействие уязвимости имеет среднюю срочность для ее устранения.
- *Green* – воздействие уязвимости имеет низкую срочность для ее устранения.
- *Clear* – воздействие уязвимости не требует срочности для ее устранения.

Заключение

В ходе работы были проанализированы 5 различных баз данных угроз и уязвимостей. Были выявлены их различия.

Таблица 2 – Итоговая сравнительная таблица

База данных угроз/уязвимостей	Отличительные черты базы
ФСТЭК	• Есть база данных угроз, и есть база данных уязвимостей; • Угрозы располагаются в хронологическом порядке, классифицированы по нарушителям и последствиям; • Уязвимости можно сортировать по идентификатору, по выявлению и по критичности; • Фильтровать угрозы и уязвимости можно на основе метрик.
Vulners	• Полноценный сайт, позволяющий искать уязвимости, эксплойты, патчи, результаты bug bounty.
X-Force	• Информация о возможном результате эксплуатации уязвимости; • Оценивание временных характеристик уязвимости; • Подробное описание уязвимостей.
Exploit Database	• Регистрация сценариев эксплуатации или примеров эксплуатации уязвимостей.
CERT/CC	• Агрегирует информацию о множестве сходных уязвимостей для какого-либо конкретного ПО.

Также были изучены несколько поколений калькулятора уязвимостей CVSS и выявлены различия в метриках. С каждой версией калькулятора разработчики стараются сделать оценку более точной и объективной, учесть как можно больше факторов и избавиться от тех метрик, которые не несут смысловую нагрузку или

оказывают незначительное влияние. Были решены задачи на оценку уязвимостей.

Список используемых источников

1. RTM Group, Кобец Д. А. Банк данных угроз безопасности информации. Что такое банк угроз ФСТЭК?: статья. 2024. URL: <https://rtmtech.ru/articles/fstek-threats-bank/#:~:text=%D0%9F%D1%80%D0%B5%D0%B6%D0%B4%D0%B5%20%D0%B2%D1%81%D0%B5%D0%B3%D0%BE%2C%20%D0%91%D0%B0%D0%BD%D0%BA%20%D0%B4%D0%B0%D0%BD%D0%BD%D1%8B%D1%85%20%D1%83%D0%B3%D1%80%D0%BE%D0%B7,%D0%B4%D0%BB%D1%8F%20%D0%B8%D0%BD%D1%84%D0%BE%D1%80%D0%BC%D0%B0%D1%86%D0%B8%D0%BE%D0%BD%D0%BD%D1%8B%D1%85%20%D1%81%D0%B8%D1%81%D1%82%D0%B5%D0%BC%20%D0%BF%D0%B5%D1%80%D1%81%D0%BE%D0%BD%D0%B0%D0%BB%D1%8C%D0%BD%D1%8B%D1%85%20%D0%B4%D0%B0%D0%BD%D0%BD%D1%8B%D1%85>. (дата обращения: 01.10.2024)
2. Хабр, Журнал «Хакер». Vulners — Гугл для хакера. Как устроен лучший поисковик по уязвимостям и как им пользоваться. 2016. URL: <https://habr.com/ru/company/xakep/blog/305262/> (дата обращения: 01.10.2024)
3. Федорченко А. В., Чечулин А. А., Котенко И. В. Исследование открытых баз уязвимостей и оценка возможности их применения в системах анализа защищенности компьютерных сетей. // Защита информации. – Санкт-Петербург, 2014. – с. 72-79.
4. Безопасность пользователей в сети Интернет. Сапожников А. Общий обзор реестров и классификаций уязвимостей (CVE, OSVDB, NVD, Secunia). 2019. URL: <https://safe-surf.ru/specialists/article/5228/607311/> (дата обращения: 01.10.2024)
5. Хабр, компания «Т.Hunter». Сравнение CVSS v.3.1 и v.4.0. 2023. URL: <https://habr.com/ru/companies/tomhunter/articles/754812/> (дата обращения: 01.10.2024)

6. Хабр, компания «Positive Technologies». Оценка уязвимостей CVSS 3.0. 2015. URL: <https://habr.com/ru/company/pt/blog/266485/> (дата обращения: 01.10.2024)
7. Хабр, компания «Информационный центр». Проблемы действующей методики определения актуальных угроз от ФСТЭК. 2019. URL: <https://habr.com/ru/company/ic-dv/blog/453756/> (дата обращения: 01.10.2024)
8. Журнал «Хакер». Меряем уязвимости: классификаторы и метрики компьютерных брешей. 2009. URL: <https://xakep.ru/2009/05/15/48221/#toc01>. (дата обращения: 01.10.2024)